

# SOC INCIDENT INVESTIGATION REPORT

## Incident 8 — Hands-on-keyboard attack launched from a compromised account

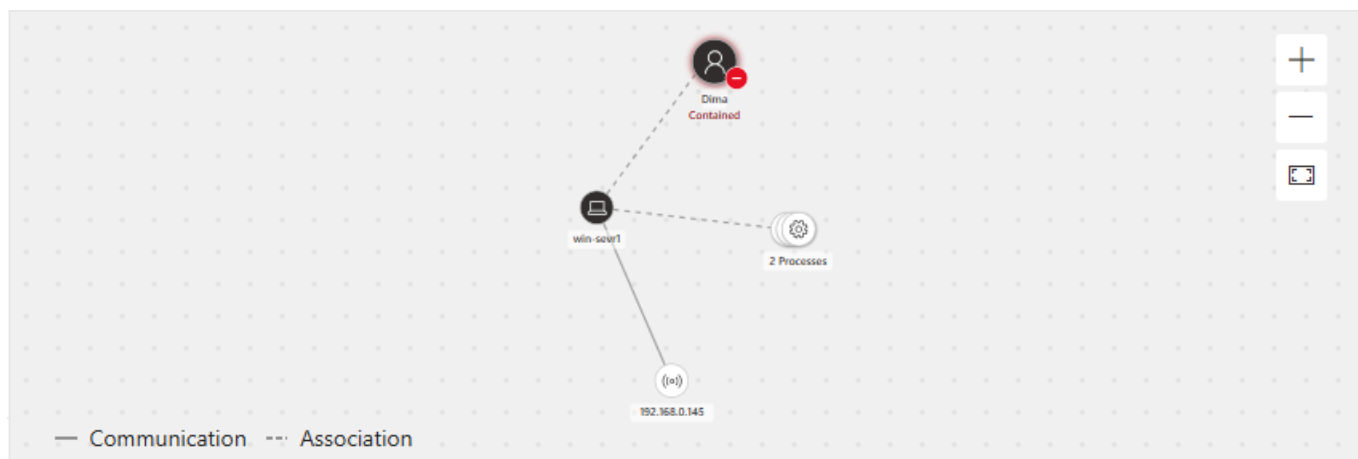
*Controlled adversary simulation | Microsoft Defender for Endpoint | Atomic Red Team*

### 1. Executive Summary

On 18 August 2026, a controlled adversary simulation was executed on endpoint win-sevr1 using Atomic Red Team technique T1003.006 — OS Credential Dumping: DCSync/Windows Credential Manager-related simulation, specifically Atomic test T1003-6, “Dump Credential Manager using keymgr.dll and rundll32.exe.” The test completed successfully with exit code 0.

Microsoft Defender for Endpoint observed a clear process chain in which powershell.exe (PID 6572) launched rundll32.exe (PID 5188) with the command keymgr,KRShowKeyMgr. Defender subsequently observed credwiz.exe (PID 1360) initiated by rundll32.exe. Defender correlated this activity with a High-severity “Potential human-operated malicious activity” alert and a subsequent “Compromised account conducting hands-on-keyboard attack” alert. Automated attack disruption also blocked an RDP session associated with the same user credentials.

The evidence supports confirmed execution of the authorized credential-access simulation and confirms strong endpoint telemetry. It does not, by itself, prove that real credentials were successfully extracted, that credentials were exfiltrated, or that the endpoint was genuinely compromised. The subsequent Defender response demonstrates the value of behavioral detection and automated containment, while also creating an important tuning question: distinguish controlled credential-access testing from genuine hands-on-keyboard activity without weakening protection.



## 2. Case Details

| Field             | Value                                                                                                                                    |
|-------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| Incident ID       | 8                                                                                                                                        |
| Endpoint          | win-sevr1                                                                                                                                |
| Account           | win-sevr1\Dima                                                                                                                           |
| Primary technique | T1003.006 / Credential Access simulation                                                                                                 |
| Atomic test       | T1003-6 — Dump Credential Manager using keymgr.dll and rundll32.exe                                                                      |
| Incident severity | High                                                                                                                                     |
| Alerts            | Potential human-operated malicious activity; Compromised account conducting hands-on-keyboard attack; Lateral movement using RDP blocked |
| Detection source  | Microsoft Defender for Endpoint / Microsoft Defender XDR                                                                                 |
| Simulation source | Atomic Red Team                                                                                                                          |
| Activity date     | 18 August 2026                                                                                                                           |

## 3. Investigation Objective

- Determine exactly what executed, under which account, and through which process chain.
- Correlate the Atomic Red Team execution with Microsoft Defender endpoint telemetry.
- Determine whether credential access was actually achieved or whether the observed activity stopped at execution of the test tooling.
- Assess why Defender classified the activity as human-operated malicious behavior and why automated attack disruption was triggered.
- Identify behavioral indicators suitable for a detection rule.
- Preserve a defensible evidence trail for SOC reporting, detection tuning, and later comparison with higher-risk tests.

## 4. Timeline and Evidence

| Time                   | Source                  | Evidence                                                               | Assessment                                                                                      |
|------------------------|-------------------------|------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| 12:54:05 VM time       | Endpoint console        | Get-Date; whoami returned win-sevr1\Dima; hostname returned win-sevr1. | Confirms test host and account. VM clock is approximately two hours behind Defender timestamps. |
| 12:56:01 VM time       | Endpoint console        | Pre-execution time check immediately before the Atomic test.           | Establishes controlled test window.                                                             |
| 12:56:04 VM time       | Atomic Red Team         | T1003-6 executed successfully; exit code 0.                            | Test execution confirmed.                                                                       |
| 14:56:04 Defender time | MDE DeviceProcessEvents | powershell.exe PID 6572 launched rundll32.exe using: & {rundll32.exe   | Strong process-chain evidence.                                                                  |

|                        |                            |                                                                                                                |                                                                                                  |
|------------------------|----------------------------|----------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
|                        |                            | keymgr,KRShowKeyMgr<br>}.                                                                                      |                                                                                                  |
| 14:56:05 Defender time | MDE<br>DeviceProcessEvents | rundll32.exe PID 5188<br>executed<br>keymgr,KRShowKeyMgr.                                                      | Confirms the LOLBin<br>execution used by the<br>test.                                            |
| 14:57:12 Defender time | MDE<br>DeviceProcessEvents | credwiz.exe PID 1360<br>was initiated by<br>rundll32.exe.                                                      | Important follow-on<br>credential-management<br>activity; requires<br>contextual interpretation. |
| 14:57:24 Defender time | MDE alert                  | Potential<br>human-operated<br>malicious activity<br>generated; category<br>Credential Access;<br>MITRE T1555. | Defender behavioral<br>detection triggered.                                                      |
| 14:58:33 Defender time | MDE alert                  | Compromised account<br>conducting<br>hands-on-keyboard<br>attack generated.                                    | Defender correlated the<br>behavior with account<br>compromise/lateral-mov<br>ement risk.        |
| 15:12:36 Defender time | Defender XDR               | Contained-user RDP<br>session<br>stopped/disconnected;<br>SessionId 6.                                         | Automated attack<br>disruption blocked an<br>RDP continuation<br>attempt.                        |
| 15:18:57 Defender time | Defender XDR               | Informational "Lateral<br>movement using RDP<br>blocked" alert generated.                                      | Confirms automated<br>containment action; does<br>not prove successful<br>lateral movement.      |

Time note: the VM and server console clocks were approximately two hours behind the Defender portal timestamps. For final incident correlation, Defender timestamps are treated as the primary enterprise timeline, while the VM timestamps are retained as the local execution reference.

## 5. Process Execution Analysis

The most important evidence is the process chain captured by Defender:

powershell.exe (PID 6572) → rundll32.exe (PID 5188) → credwiz.exe (PID 1360)

The initiating PowerShell command was:

"powershell.exe" & {rundll32.exe keymgr,KRShowKeyMgr}

The rundll32 command line was:

"rundll32.exe" keymgr,KRShowKeyMgr

The follow-on process was credwiz.exe, located at C:\Windows\System32\credwiz.exe. Defender reported that the binary is Microsoft-signed, has a VirusTotal detection ratio of 0/70, and is widely prevalent. These properties strongly support that credwiz.exe itself is a legitimate Windows binary rather than malware. The security significance comes from the execution context and process chain, not from the file being malicious.

The failed local CIM query for the historical PIDs is not treated as contradictory evidence. Those PIDs had already exited by the time the query was run. Defender's historical process telemetry is therefore the authoritative source for the process relationship in this investigation.

## 6. Defender Detection and Correlation

Microsoft Defender for Endpoint/XDR generated and correlated the following activity:

- Potential human-operated malicious activity — High; Credential Access; MITRE T1555: Credentials from Password Stores.
- Compromised account conducting hands-on-keyboard attack — High; Lateral Movement; automated attack disruption initiated.
- Lateral movement using RDP blocked — Informational; MITRE T1021.001: Remote Desktop Protocol.

Defender correlated the alerts using the same device and the same user credentials. The incident evidence also associated the activity with win-sevr1\Dima and the SID ending in -500. This is significant because the account used in the lab was the same account under which the Atomic test was intentionally executed.

A private network address, 192.168.0.145, was also surfaced as suspicious evidence. At this stage it should be treated as an indicator requiring validation rather than automatically labelled malicious. Its role should be established from the device timeline and network telemetry before being used as an IOC.

## 7. Findings

| Finding                                  | Status          | Assessment                                                                                                                  |
|------------------------------------------|-----------------|-----------------------------------------------------------------------------------------------------------------------------|
| Atomic test execution                    | Confirmed       | T1003-6 completed successfully with exit code 0.                                                                            |
| PowerShell execution                     | Confirmed       | PowerShell PID 6572 executed the test command.                                                                              |
| rundll32 credential-management execution | Confirmed       | PID 5188 executed keymgr,KRShowKeyMgr.                                                                                      |
| Follow-on credwiz execution              | Confirmed       | PID 1360 was initiated by rundll32.exe.                                                                                     |
| Account attribution                      | Confirmed       | Activity was associated with win-sevr1\Dima.                                                                                |
| Credential-access behavior               | Confirmed       | Defender classified the behavior under Credential Access/T1555.                                                             |
| Credential extraction                    | Not established | No evidence supplied demonstrates that a credential value or secret was successfully extracted.                             |
| Credential exfiltration                  | Not observed    | No supplied evidence establishes outbound transfer of recovered credentials.                                                |
| Malware execution                        | Not established | The key binaries observed are legitimate Windows components; the activity was generated by an authorized Atomic simulation. |
| Automated containment                    | Confirmed       | Defender XDR stopped/disconnected an RDP session for the contained user.                                                    |

|                             |                 |                                                                                         |
|-----------------------------|-----------------|-----------------------------------------------------------------------------------------|
| Successful lateral movement | Not established | RDP was blocked; the evidence does not demonstrate successful movement to another host. |
| Destructive impact          | None observed   | The test was controlled and no destructive behavior was reported.                       |

## 8. Analyst Reasoning and Investigation Narrative

- Initial hypothesis: credential-access tooling may have been executed under a user account and could indicate preparation for lateral movement.
- Execution validation: the Atomic Red Team command was intentionally run and returned exit code 0, confirming that the observed behavior was part of the controlled test.
- Process validation: Defender independently captured PowerShell spawning rundll32.exe and the exact keymgr command, giving strong evidence that the behavior occurred rather than merely being present on disk.
- Follow-on validation: credwiz.exe appeared as a child of rundll32.exe. Because credwiz.exe is a legitimate Microsoft-signed Windows binary, the investigation focuses on its context rather than treating it as malware.
- Impact assessment: Defender's RDP containment action demonstrates that the endpoint protection platform interpreted the sequence as sufficiently risky to disrupt possible lateral movement.
- Scope assessment: no supplied evidence proves successful credential theft, exfiltration, or lateral movement. The case therefore remains a confirmed security-control detection of a credential-access simulation, not a confirmed real-world compromise.
- SOC lesson: the strongest evidence is the combination of user context, parent/child process relationships, command line, timing, and subsequent defense response. A single binary name would be much weaker evidence.

## 9. Detection Engineering Hypothesis

Behavior: PowerShell → rundll32.exe → keymgr/credential-management activity, followed by credential-related Windows processes and/or lateral-movement attempts.

The detection should target the behavior rather than the Atomic test number. A robust analytic should increase confidence when rundll32.exe invokes credential-management DLL exports or keymgr functionality from an interactive PowerShell session, especially when the same account subsequently attempts RDP or other remote-service activity.

## 10. Baseline Microsoft Defender Advanced Hunting Query

```
DeviceProcessEvents
| where Timestamp > ago(24h)
| where FileName =~ "rundll32.exe"
| where ProcessCommandLine has_any ("keymgr", "KRShowKeyMgr")
| project Timestamp, DeviceName, AccountName,
    InitiatingProcessFileName, InitiatingProcessCommandLine,
    FileName, ProcessCommandLine, ProcessId, InitiatingProcessId
| order by Timestamp desc
```

This is a focused baseline analytic for the observed behavior. It should not be deployed as a high-confidence production rule without testing. A stronger production version should correlate the rundll32 event with the initiating PowerShell context, user type, device role, and nearby credential-access or lateral-movement activity.

## 11. Detection Tuning Plan

- Baseline legitimate administrative use of rundll32.exe, keymgr.exe/keymgr.dll, Credential Manager, and credwiz.exe.
- Increase severity when PowerShell is the initiating process and the command line references keymgr/KRShowKeyMgr.
- Increase confidence when the same user performs RDP, SMB, WinRM, or other remote-service activity shortly afterward.
- Correlate with credential-store access, suspicious network connections, unusual logon sessions, and additional credential-access techniques.
- Use account privilege and role as context; a privileged administrator performing this sequence should receive different risk scoring from a standard user.
- Do not suppress the detection solely because the endpoint is a lab machine; instead, use explicit lab/test tagging if this were an operational environment.
- Validate the rule against benign Windows administrative workflows to measure false positives before enabling automated response.

## 12. Analyst Assessment and Disposition

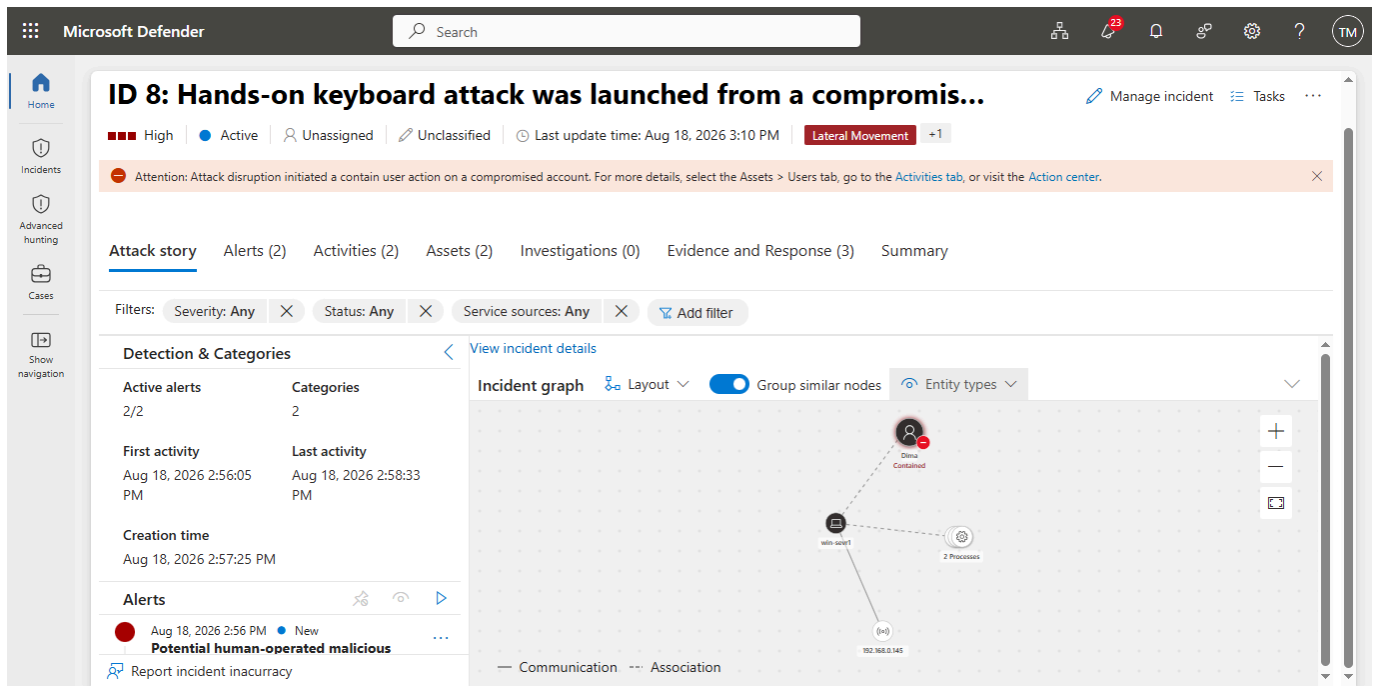
Assessment: TRUE POSITIVE for the behavioral detection and TRUE POSITIVE for the controlled Atomic Red Team execution, but NOT evidence of an actual compromise.

The evidence supports a confirmed credential-access simulation. Defender successfully captured the process chain and escalated the sequence to high-severity behavioral detections. Automated attack disruption also blocked an RDP session associated with the contained account. There is insufficient evidence in the supplied telemetry to conclude that credentials were successfully dumped or exfiltrated, or that lateral movement succeeded.

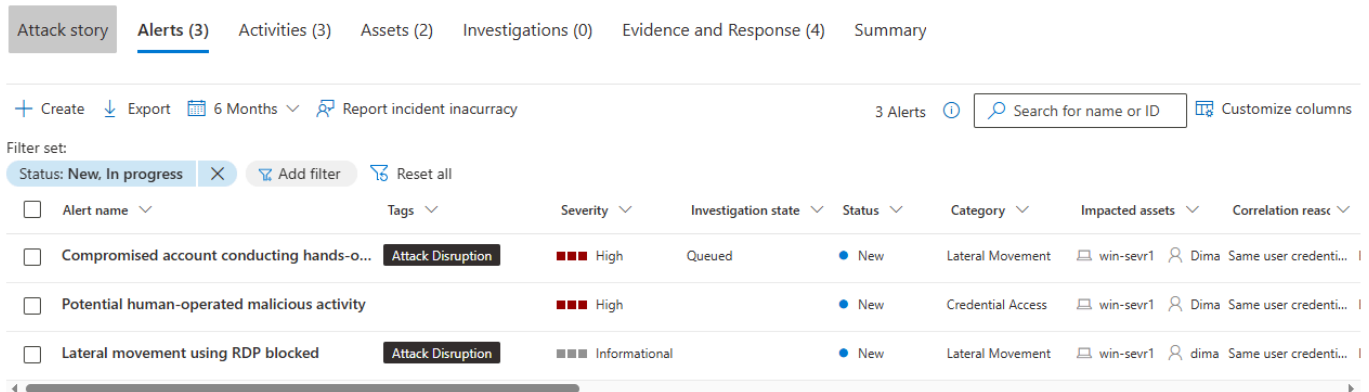
Recommended disposition: preserve the evidence and document the Atomic test identifier before closing the lab incident. Retain the analytic as a candidate detection and use subsequent tests to determine whether the same behavior produces appropriate alerts without excessive false positives.

## 13. Screenshot / Evidence Placeholders

**Screenshot A — Incident 8 overview showing severity, first activity, last activity, and impacted asset.**

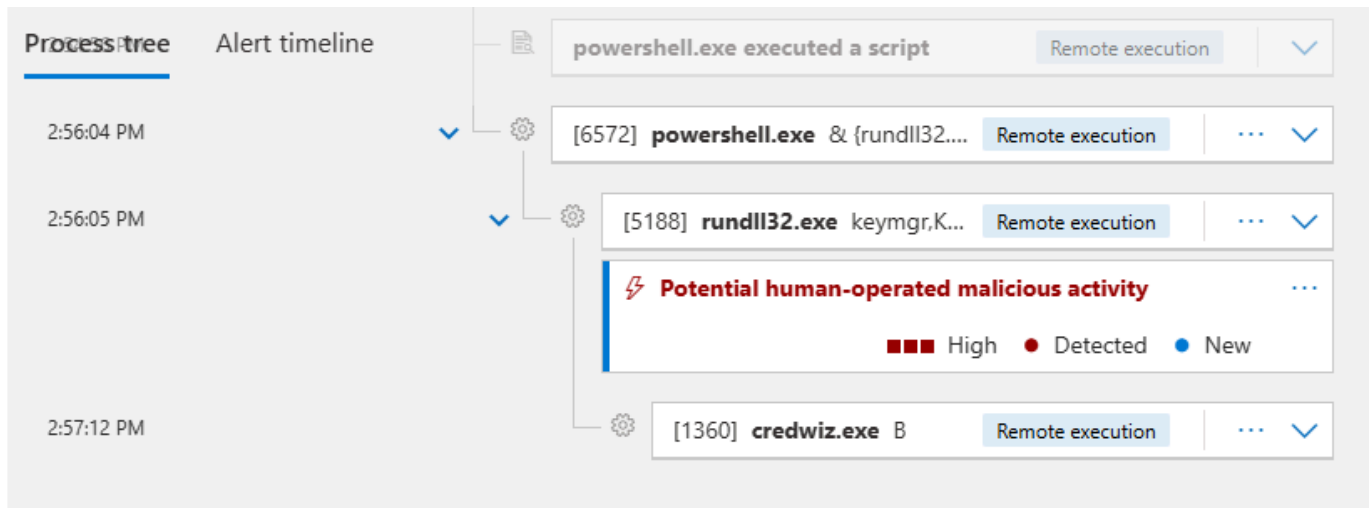


**Screenshot B — Potential human-operated malicious activity alert showing T1555/Credential Access.**

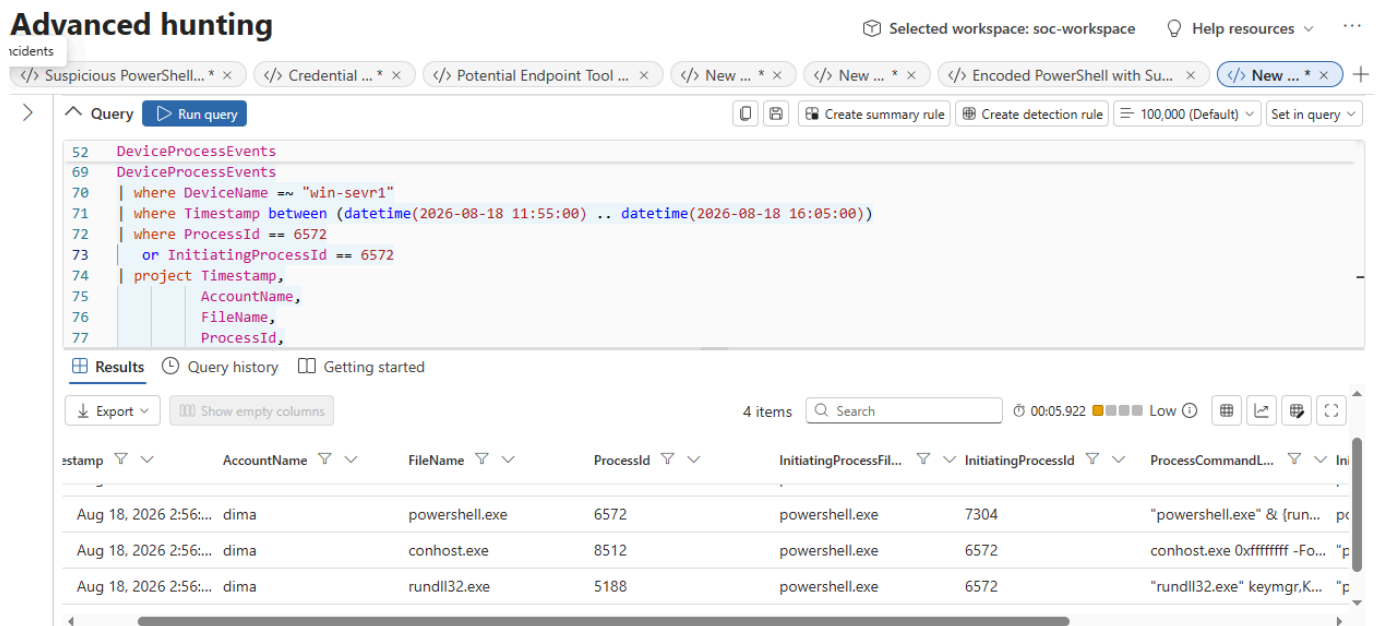


Analyst notes: Attackers might search for common password storage locations to obtain user credentials which can be used to perform lateral movements and access restricted information.

**Screenshot C — Process tree showing PowerShell PID 6572 → rundll32 PID 5188 → credwiz PID 1360.**



Screenshot D — Defender process details for powershell.exe PID 6572 and the keymgr command line.



Screenshot E — Defender process details for rundll32.exe PID 5188.



# Advanced hunting

Selected workspace: soc-workspace    Help resources    ...

Suspicious PowerShell... \* x    Credential ... \* x    Potential Endpoint Tool ... x    New ... \* x    New ... \* x    Encoded PowerShell with Su... x    New ... \* x +

Query    Run query    Create summary rule    Create detection rule    100,000 (Default)    Set in query

```
52 DeviceProcessEvents
69 DeviceProcessEvents
70 | where DeviceName =~ "win-sevr1"
71 | where Timestamp between (datetime(2026-08-18 11:55:00) .. datetime(2026-08-18 16:05:00))
72 | where ProcessId == 5188
73 | or InitiatingProcessId == 5188
74 | project Timestamp,
75 |     AccountName,
76 |     FileName,
77 |     ProcessId,
```

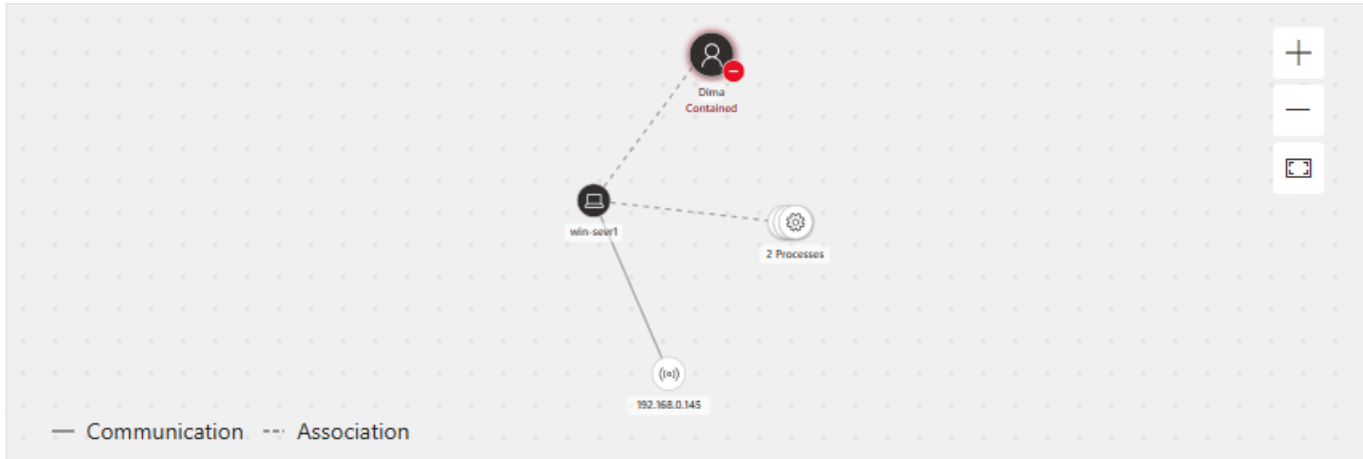
Results    Query history    Getting started

Export    Show empty columns    2 items    Search    00:06.912    Low

Filters: Add filter

| Timestamp             | AccountName | FileName     | ProcessId | InitiatingProcessFileName | InitiatingProcessId | ProcessCommandLine         | InitiatingProcessCommandLine |
|-----------------------|-------------|--------------|-----------|---------------------------|---------------------|----------------------------|------------------------------|
| Aug 18, 2026 2:56:... | dima        | rundll32.exe | 5188      | powershell.exe            | 6572                | "rundll32.exe" keymgr,K... | "p...                        |
| Aug 18, 2026 2:57:... | dima        | credwiz.exe  | 1360      | rundll32.exe              | 5188                | credwiz.exe B              | "n...                        |

Screenshot F — Compromised account conducting hands-on-keyboard attack alert.



Analyst notes: Defenter pro-actively contained user and isolated the end point.

Screenshot G — RDP blocked / attack disruption event.

Related blocking events

Export    2 items    Customize columns

| Timestamp             | DeviceName | ActionType              | AccountSid            | AccountDomain |
|-----------------------|------------|-------------------------|-----------------------|---------------|
| Aug 18, 2026 3:12:... | win-sevr1  | ContainedUserRemoteD... | S-1-5-21-108073371... | win-sevr1     |
| Aug 18, 2026 3:12:... | win-sevr1  | ContainedUserRemoteD... | S-1-5-21-108073371... | win-sevr1     |

Screenshot H — Advanced Hunting query and returned telemetry.

Export Show empty columns

4 items Search 00:03.466 Low

Filters: Add filter

| Timestamp              | DeviceName | AccountName | FileName       | ProcessId | InitiatingProcessFil... | InitiatingProcessId | InitiatingProcessCo...     |
|------------------------|------------|-------------|----------------|-----------|-------------------------|---------------------|----------------------------|
| > Aug 18, 2026 2:56... | win-sevr1  | dima        | powershell.exe | 6572      | powershell.exe          | 7304                | powershell.exe             |
| > Aug 18, 2026 2:56... | win-sevr1  | dima        | conhost.exe    | 8512      | powershell.exe          | 6572                | "powershell.exe" & {run... |
| > Aug 18, 2026 2:56... | win-sevr1  | dima        | rundll32.exe   | 5188      | powershell.exe          | 6572                | "powershell.exe" & {run... |
| > Aug 18, 2026 2:57... | win-sevr1  | dima        | credwiz.exe    | 1360      | rundll32.exe            | 5188                | "rundll32.exe" keymgr,K... |

Screenshot I — Device timeline around 14:56–15:13 Defender time.

| Activity started     | Title                                       | Type           | Category     | Target                   | Performed by           |
|----------------------|---------------------------------------------|----------------|--------------|--------------------------|------------------------|
| Aug 18, 2026 3:18 PM | Alert 'Lateral movement using RDP bloc...   | Alert link     | Correlations |                          | Microsoft Defender XDR |
| Aug 18, 2026 3:17 PM | S-1-5-21-108073371-2357116548-1371...       | Uncontain User | Response     | S-1-5-21-108073371-23... | Attack Disruption      |
| Aug 18, 2026 3:09 PM | Dima contained                              | Contain User   | Response     | Dima                     | Attack Disruption      |
| Aug 18, 2026 3:09 PM | Alert 'Compromised account conducting...    | Alert link     | Correlations |                          | Microsoft Defender XDR |
| Aug 18, 2026 2:57 PM | Alert 'Credentials accessed from passwor... | Alert link     | Correlations |                          | Microsoft Defender XDR |

14. Limitations

- The investigation is based on the supplied Defender incident evidence and terminal output; no memory image or full disk forensic acquisition was performed.
- Historical PIDs were no longer active when queried locally, so current CIM output could not reconstruct the exited processes.
- No supplied evidence demonstrates successful extraction of credential material or credential exfiltration.
- The role of 192.168.0.145 remains unvalidated and should not be treated as a confirmed malicious IOC without network correlation.
- The Defender incident was generated by a controlled Atomic Red Team simulation, so its alert severity should not be interpreted as proof of a genuine attacker compromise.
- The VM/server clock differed from Defender timestamps by approximately two hours; Defender timestamps should be used for enterprise correlation.

15. Next Phase

Proceed to the next controlled test only after preserving this evidence and, where possible, exporting the relevant Defender process and alert views. The next test should challenge a different behavioral hypothesis, preferably an endpoint-compromise indicator or persistence technique. The investigation should again follow the same workflow: hypothesis → execution → telemetry collection → process-tree reconstruction → scope → impact assessment → detection engineering → tuning → formal disposition.

Higher-risk simulations and controlled malware investigation should remain isolated and should be introduced only after the current detection and containment behavior is fully understood. The goal is to increase investigative depth without unnecessarily damaging the lab endpoint.

## **16. Case Conclusion**

Incident 8 demonstrates that Microsoft Defender for Endpoint/XDR provided sufficient telemetry to reconstruct a credential-access simulation from the initiating PowerShell process through rundll32.exe and into credwiz.exe. The platform recognized the sequence as credential-access and hands-on-keyboard behavior and initiated automated disruption against an RDP session associated with the same user credentials.

The investigation establishes a defensible conclusion: the Atomic Red Team test executed successfully and generated real endpoint security telemetry, the detection and containment controls worked as intended, and the observed binaries were legitimate Windows components used in a suspicious execution context. However, the available evidence does not establish actual credential theft, credential exfiltration, successful lateral movement, or malware execution. The strongest detection opportunity is therefore behavioral correlation around credential-management LOLBins, PowerShell context, user identity, and subsequent remote-access activity.